

CHOWDHURY HASAN MAHMUD

Senior Cybersecurity Program Leader | Acting CISO | AI-Aided Security & Agentic AI Governance

CISM • CISA • PMP • CCSP • ITIL 4 • GSEC

NYC Metro | (347) 836-2171 | hasanpmpro@gmail.com | linkedin.com/in/chowdhury-hasan-mahmud | Open to Remote / Hybrid / Federal

PROFESSIONAL SUMMARY

Cybersecurity and IT program executive with 18 years leading enterprise information security, GRC, and mission-critical technology programs across public safety, public health, healthcare, and global enterprise environments. Acting CISO for NYC's largest public safety agency with a proven record of building zero-trust, AI-aided security operations and delivering SOC 2 Type II, FedRAMP, ISO 27001, NIST 800-53, HIPAA, and NYDFS compliance under regulatory scrutiny.

Early adopter of Agentic AI in cybersecurity — designing AI-assisted SOC workflows, LLM-powered threat triage, and AI governance programs aligned to NIST AI RMF, ISO/IEC 42001, and the EU AI Act. Combines hands-on technical depth (EDR, SIEM, cloud, IAM, vulnerability management) with PMP-disciplined portfolio leadership and executive communication for board-level audiences. Open to Senior Cyber PMO / ISSO / AI Security Lead / ACISO roles in NYC, remote US-wide, and federal/state/city government.

CORE COMPETENCIES

- Cybersecurity Program Leadership & Acting CISO Operations
- AI-Aided Cybersecurity & Agentic AI Governance (NIST AI RMF, ISO 42001, EU AI Act)
- Risk Management, GRC & Regulatory Compliance (NIST 800-53/CSF/RMF, ISO 27001, SOC 2, FedRAMP, HIPAA, NYDFS, CJIS)
- Incident Response, Threat Intelligence & Business Continuity / Disaster Recovery
- Zero-Trust Architecture, Cloud Security (Azure/AWS), SIEM, EDR/XDR, IAM, PAM, DLP
- LLM Security, OWASP LLM Top 10, MITRE ATLAS, AI Red-Teaming, Model & Agent Risk
- Enterprise Project / Portfolio Management (PMP, Agile, Scrum, SAgE, DevSecOps, PMO)
- Vendor Risk Management, Contract Negotiation, Third-Party Assurance
- Executive & Board Reporting, KRI/KPI Dashboards, Security Metrics
- Team Leadership, Mentorship, Cross-Functional Stakeholder Management

PROFESSIONAL CERTIFICATIONS

CISM (ISACA) • CISA (ISACA) • CCSP (ISC²) • PMP (PMI) • ITIL 4 Foundation • GIAC GSEC • CCNA Security • (In Progress) IAPP AIGP, ISO/IEC 42001 Lead Implementer

PROFESSIONAL EXPERIENCE

Fire Department of the City of New York (FDNY) — Brooklyn, NY

Acting CISO / Senior Cybersecurity Posture Manager & ISSO | 2016 – Present

- Serve as Acting CISO and Senior Cybersecurity Posture Manager for NYC's largest public safety agency (17,000+ employees, 2M+ annual emergency calls), owning enterprise security strategy, incident response, and business continuity for 911/CAD, EMS, and mission-critical platforms.
- Direct a multi-million-dollar cybersecurity portfolio covering cloud migration, zero-trust architecture, SIEM, EDR/XDR, PAM, and AI-assisted threat detection across hybrid Azure/AWS and on-premises environments.
- Led FDNY to become the first major metropolitan fire department to achieve SOC 2 Type II certification; delivered FedRAMP authorization for EMS cloud systems and maintained a 98% audit pass rate across NIST 800-53, ISO 27001, HIPAA, CJIS, and NYDFS Part 500.
- Deployed CrowdStrike Falcon EDR on 800+ endpoints, implemented DMARC with GCA (90% reduction in email spoofing), and drove a 70% reduction in critical vulnerability exposure via Rapid7, Tenable, Qualys, and ARMIS.
- Stood up AI-aided SOC workflows using GenAI copilots and agentic automation for triage, alert enrichment, threat hunting, and phishing analysis, accelerating mean-time-to-contain and reducing analyst toil.

- Lead end-to-end incident lifecycle management for 40+ annual security events in coordination with NYC Cyber Command, with zero operational disruption to emergency services.
- Manage vendor risk for 50+ third parties (Motorola, Accenture, CrowdStrike, Fortinet, Palo Alto, Forcepoint); negotiate SLAs and contracts and provide executive and board-level reporting on KRIs, posture, and program maturity.
- Designed AI governance controls (model inventory, data lineage, prompt & output logging, red-team protocols) for emerging GenAI and agentic AI use cases supporting FDNY and citywide pilots.
- Provided board-level analytics and cyber posture reports to FDNY executive staff, NYC DCAS, OTI, and oversight committees.

NYC Department of Health & Mental Hygiene (DOHMH) — Queens, NY

Technical Innovation & Cybersecurity Program Manager | 2012 – 2016

- Managed enterprise cybersecurity and IT modernization programs for NYC Department of Health & Mental Hygiene, securing 40+ healthcare applications serving 8.5M residents.
- Delivered HIPAA Security Rule, NYDFS Part 500, NIST CSF, and ISO 27001 compliance; implemented IAM, MFA, SIEM (Splunk), and vulnerability management across Azure and AWS.
- Led rapid security authorization of 15 emergency response platforms during COVID-19, meeting compressed timelines without compromising regulatory posture.
- Established DevSecOps pipeline practices, zero-trust architecture baselines, and cross-agency GRC processes adopted by C-Suite and city leadership.

Earlier Experience

- Medisys Health Network — IT Risk Analyst & Compliance Officer (2009–2012): Led HIPAA, SOX, and PCI-DSS compliance for a 3,000-user healthcare network; reduced critical exposures by 60% through automated vulnerability management and remediation workflows.
- G-Star RAW (Amsterdam, NL) — Risk & IT Governance Analyst / EDI & 3PL PM (2007–2009): Led controls, vendor risk reviews, EDI integration, and supply-chain technology projects for EU payment and health systems.
- King Saud Medical City (Riyadh, KSA) — Head of Technical & EHR Development (2008–2012, concurrent): Directed hospital computerization, EMR, and IVR rollouts, migrating manual workflows to enterprise automation.

KEY ACHIEVEMENTS

- SOC 2 Type II — first major metropolitan fire department to achieve certification.
- FedRAMP authorization delivered for mission-critical EMS cloud systems.
- 70% reduction in critical vulnerability exposure through risk-based remediation.
- 90% reduction in email spoofing after DMARC deployment with Global Cyber Alliance.
- 98% audit pass rate across NIST 800-53, ISO 27001, HIPAA, CJIS, NYDFS.
- 99.97% uptime maintained for 911/CAD during major cybersecurity upgrades.
- Stood up AI-aided SOC copilots that reduced analyst triage time and false positives.
- Secured 15 emergency response platforms in compressed timelines during COVID-19.

TECHNICAL PROFICIENCIES

AI & Agentic Security: NIST AI RMF 1.0, ISO/IEC 42001, EU AI Act, OWASP LLM Top 10, MITRE ATLAS, LangChain/LlamaIndex security patterns, Model Context Protocol (MCP) security, prompt-injection & jailbreak defense, AI red-teaming, Microsoft Security Copilot, Google SecLM, Azure AI Content Safety, Purview for AI governance

Security Frameworks: NIST 800-53 / CSF / RMF, ISO 27001/27017/27018, SOC 2 Type II, FedRAMP, CJIS, HIPAA Security Rule, PCI-DSS, NYDFS Part 500, COBIT, CIS Controls v8

Detection & Response: CrowdStrike Falcon EDR/XDR, Splunk ES, IBM QRadar, LogRhythm, Microsoft Sentinel, ExtraHop, Carbon Black

Cloud & Network: Microsoft Azure (Defender, Sentinel, Purview), AWS (GuardDuty, Security Hub, IAM), CSPM, Palo Alto, Fortinet FortiGate/FortiNAC, Cisco Firepower, Zero-Trust Architecture

IAM & PAM: Okta, Azure AD/Entra ID, CyberArk, SailPoint IdentityIQ, SAML/OAuth/OIDC, MFA, PKI

Vulnerability & Offensive: Rapid7 InsightVM, Tenable Nessus, Qualys, ARMITIS, Burp Suite Pro, Metasploit, OWASP ZAP

DevSecOps & Automation: Jenkins, GitHub Actions, GitLab CI/CD, Docker, Kubernetes, Terraform, IaC scanning, Python, PowerShell, Bash

GRC & PMO: ServiceNow GRC, RSA Archer, MetricStream, Jira, Confluence, MS Project, Oracle PPM, HP ALM

EDUCATION

B.Sc., Business Information Systems — University of East London, United Kingdom

Diploma, Information Technology & Engineering — University of Queensland, Australia